

Educação Profissional Paulista

Técnico em
**Ciência de
Dados**



**GOVERNO DO ESTADO
DE SÃO PAULO**

Privacidade e Lei Geral de Proteção de Dados

Responsabilidades das organizações sob a LGPD

Aula 2

Código de aula: [DADOS]ANO2C6B2S12A2



Exposição



Objetivo da aula

- Introduzir os conceitos elementares de privacidade e proteção de dados.



Competências da Unidade (técnicas e socioemocionais)

- Compreender e dominar os princípios da privacidade e da proteção de dados e como aplicá-los na construção de algoritmos de inteligência artificial;
- Analisar situações complexas, avaliar diferentes perspectivas e prever as consequências de decisões e ações;
- Entender os atuais desafios da Lei Geral de Proteção de Dados no ambiente da IA.



Recursos didáticos

- Recurso audiovisual para exibição de textos, vídeos e imagens;
- Acesso ao laboratório de informática e/ou à internet.



Duração da aula

50 minutos.

Princípios de segurança da informação

Confidencialidade: este princípio visa **proteger informações sensíveis** de acessos não autorizados. Um exemplo de implementação é o uso de criptografia de ponta a ponta em comunicações corporativas, garantindo que apenas o remetente e o destinatário possam acessar o conteúdo da mensagem.

Integridade: refere-se à **precisão e consistência dos dados** ao longo de todo o seu ciclo de vida. Um exemplo seria a utilização de *hashes* e somas de verificação para validar a integridade dos dados durante transferências ou armazenamento.



Tome nota

Hash é um algoritmo matemático que transforma qualquer bloco de dados em uma série de caracteres de comprimento fixo.

Princípios de segurança da informação

Disponibilidade: assegura que os **dados e recursos de TI estejam disponíveis para usuários autorizados** quando necessário. Um exemplo prático é a implementação de sistemas redundantes e *backups* regulares para prevenir interrupções no caso de falhas de sistema ou desastres naturais.

Exposição

Implementação de controles de segurança



Controles físicos

Incluem medidas como fechaduras biométricas para salas de servidores, prevenindo o acesso físico não autorizado a hardware crítico.



Controles técnicos

Implementados por meio de tecnologia, como *firewalls* de próxima geração para filtrar tráfego de rede malicioso e sistemas de detecção de intrusão para alertar sobre atividades suspeitas.



Controles administrativos

Relacionam-se a políticas e procedimentos, como programas de treinamento de conscientização em segurança cibernética, que educam os funcionários sobre como evitar *phishing* e outros tipos de ataques cibernéticos.

Estratégias para implementação eficaz de controles de segurança

Estratégias para implementação eficaz de controles

- **Análise de risco:** uma análise de risco detalhada pode revelar que dados financeiros são o ativo mais valioso de uma organização, levando à implementação de controles mais rigorosos nessa área, como autenticação multifatorial para acesso a sistemas financeiros.
- **Política de segurança da informação:** uma política eficaz poderia incluir a exigência de senhas fortes e atualizações regulares de *software*, além da definição de responsabilidades específicas para a equipe de TI em relação à manutenção da segurança.

Estratégias para implementação eficaz de controles de segurança

Estratégias para implementação eficaz de controles

- **Treinamento e conscientização:** programas regulares de treinamento podem incluir simulações de ataques de engenharia social, ajudando a preparar os funcionários para reconhecer e responder adequadamente a tentativas de *phishing*.



Tome nota

Phishing é o crime de enganar as pessoas para que compartilhem informações confidenciais como senhas e número de cartão de crédito.

Exposição

Plano de resposta a incidentes de segurança

Definição: um plano de resposta a incidentes de segurança é um conjunto de instruções e procedimentos projetados para identificar, responder e recuperar-se de incidentes de segurança de dados, como violações ou ataques cibernéticos.

Importância: este plano é crucial porque permite uma resposta rápida e eficiente, minimizando os danos e reduzindo o tempo de recuperação após um incidente.



Exemplo

No caso de um ataque *ransomware*, um plano de resposta bem desenvolvido pode ajudar a limitar a propagação do *malware* e acelerar o processo de recuperação dos sistemas afetados.

Plano de resposta a incidentes de segurança

Desenvolvimento e implementação de um plano efetivo

- **Preparação:** inclui a formação de uma equipe de resposta a incidentes, com clara atribuição de papéis e responsabilidades. A preparação também envolve a realização de treinamentos regulares e simulações de incidentes para garantir que a equipe esteja pronta para agir.
- **Identificação do incidente:** este passo envolve o monitoramento contínuo dos sistemas para detectar atividades suspeitas ou anormais. Por exemplo, um sistema de detecção de intrusão pode identificar um aumento incomum no tráfego de rede, sinalizando uma possível violação de segurança.

Plano de resposta a incidentes de segurança

Desenvolvimento e implementação de um plano efetivo

- **Contenção:** após a identificação de um incidente, ações imediatas são necessárias para limitar o escopo e a magnitude do impacto. Isso pode incluir isolar redes ou sistemas afetados para evitar a propagação do incidente.
- **Erradicação:** uma vez contido, o próximo passo é remover a causa do incidente, como *malwares* ou acessos não autorizados, dos sistemas afetados. Isso pode envolver a atualização de sistemas, a aplicação de *patches* de segurança ou a alteração de senhas.

Plano de resposta a incidentes de segurança

Desenvolvimento e implementação de um plano efetivo

- **Recuperação:** nesta fase, os sistemas, os dados e as funções afetadas são restaurados ao seu estado normal de operação. Por exemplo, isso pode incluir a restauração de dados a partir de *backups* ou a reconstrução de sistemas comprometidos.
- **Pós-incidente:** após a resolução do incidente, é vital realizar uma análise pós-incidente para entender o que aconteceu, como foi tratado e como prevenir incidentes semelhantes no futuro. Isso pode resultar em atualizações no plano de resposta a incidentes e em melhorias nas práticas de segurança.



Vamos
fazer uma
atividade

Estudo de caso para simulação de incidente de segurança de dados: ataque de *ransomware* na Tech Solutions

Cenário do incidente

Tech Solutions, uma empresa de tecnologia, sofre um ataque de ***ransomware***. O ataque começou por um e-mail de ***phishing*** enviado a um funcionário, levando à rápida criptografia de dados importantes e uma demanda de resgate. O sistema de detecção de intrusão alerta a equipe de TI sobre atividades suspeitas.

Situação fictícia elaborada especialmente para o curso.

Objetivos da simulação

Os alunos, divididos em grupos, atuarão como a equipe de resposta a incidentes da empresa Tech Solutions. Eles devem desenvolver uma estratégia de resposta ao incidente seguindo as etapas de identificação, contenção, erradicação e recuperação.



Vamos
fazer uma
atividade

Essa atividade deverá ser
entregue no AVA (Ambiente
Virtual de Aprendizagem)



**Confira ao lado as
questões para
discussão em grupo**

Estudo de caso: ataque de *ransomware* na Tech Solutions

- 1** **Identificação do incidente:**
 - Como o *ransomware* provavelmente entrou no sistema?
 - Quais sistemas e dados foram afetados?
- 2** **Contenção do incidente:**
 - Que medidas imediatas sua equipe tomaria para conter a propagação do *ransomware*?
- 3** **Erradicação do incidente:**
 - Como sua equipe removeria o *ransomware* dos sistemas afetados?
 - Que ações seriam realizadas para prevenir incidentes futuros semelhantes?
- 4** **Recuperação do incidente:**
 - Qual é o plano para restaurar os sistemas e dados afetados?
 - Como a empresa retomaria as operações normais?
- 5** **Avaliação pós-incidente:**
 - Quais lições foram aprendidas com esse incidente?
 - Que mudanças poderiam ser feitas no plano de resposta a incidentes com base nessa experiência?

Elabore as respostas e envie pelo AVA.



O que nós
aprendemos
hoje?

© Getty Images

Hoje desenvolvemos:

- 1** O conhecimento sobre os princípios de segurança da informação, seus conceitos e sua aplicação prática;
- 2** A compreensão das etapas e ações que devem ser realizadas para a elaboração de um plano de resposta a incidentes de segurança;
- 3** Um exercício prático para análise de incidente de segurança cibernética, a elaboração de estratégias de resposta e a aplicação de um plano de resposta a incidentes.

Saiba mais

A **cibersegurança**, também chamada de segurança de computadores ou segurança da tecnologia da informação, abrange **técnicas e ações** que têm como objetivo **proteger** sistemas, programas, equipamentos, redes e pessoas de ataques cibernéticos, crimes virtuais e terrorismo cibernético. **Leia mais** sobre no link abaixo:

BOCK, M. M. O que é cibersegurança: práticas e as equipes de segurança. *Alura*, 16 fev. 2022. Disponível em:
<https://www.alura.com.br/artigos/o-que-e-ciberseguranca-praticas-equipes-de-seguranca>. Acesso em: 12 mar. 2024.

Referências da aula

BOCK, M. M. O que é cibersegurança: práticas e as equipes de segurança. *Alura*, 16 fev. 2022. Disponível em: <https://www.alura.com.br/artigos/o-que-e-ciberseguranca-praticas-equipes-de-seguranca>. Acesso em: 12 mar. 2024.

BRASIL. Ministério da Justiça e Segurança Pública. Autoridade Nacional de Proteção de Dados. *Perguntas frequentes – ANPD*, fev. 2023. Disponível em: <https://www.gov.br/anpd/pt-br/aceso-a-informacao/perguntas-frequentes-2013-anpd>. Acesso em: 12 mar. 2024.

BRASIL. *Lei nº 13.709, de 14 de agosto de 2018*. Lei Geral de Proteção de Dados Pessoais (LGPD). Disponível em: https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/L13709.htm. Acesso em: 12 mar. 2024.

FRAZÃO, A.; CARVALHO, A. P.; MILANEZ, G. *Curso de proteção de dados – fundamentos da LGPD*. São Paulo: Forense, 2022.

MALDONADO, V. N (Coord.). *LGPD – Lei Geral de Proteção de Dados Pessoais. Manual de Implementação*. São Paulo: Thomson Reuters, 2022.

Identidade visual: imagens © Getty Images

Educação Profissional Paulista

Técnico em
**Ciência de
Dados**



**GOVERNO DO ESTADO
DE SÃO PAULO**